

# WebPwn Advanced Pentest Report

**Target:** https://holbertonschool.az/

**Date:** 2026-05-12 15:05 | Generated by WebPwn Senior Pentest Module

## Executive Summary

This report presents the findings of an advanced automated security assessment against https://holbertonschool.az/. The assessment utilized senior-level heuristics to identify critical vulnerabilities across OWASP Top 10 categories. A total of 138 security findings were recorded.

| Severity | Count |
|----------|-------|
| CRITICAL | 42    |
| HIGH     | 44    |
| MEDIUM   | 12    |
| LOW      | 2     |
| INFO     | 39    |

## Detailed Security Findings

### #1 [CRITICAL] Unauthenticated Admin Access

**Location:** https://holbertonschool.az/admin/

**CVSS Score:** 9.1

**Technical Details:** Admin path accessible without authentication: /admin/

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Restrict admin paths to authenticated and authorized users only.

### #2 [CRITICAL] Secret Leakage in JS — Password

**Location:** https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

### #3 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

### #4 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

### #5 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

### #6 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

## #7 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

## #8 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

## #9 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

## #10 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Remove secrets from client-side JS. Use server-side environment variables.

---

## #11 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Remove secrets from client-side JS. Use server-side environment variables.

---

## #12 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Remove secrets from client-side JS. Use server-side environment variables.

---

## #13 [CRITICAL] Secret Leakage in JS — Password

**Location:** <https://analytics.tiktok.com/i18n/pixel/static/main.MWJkOTJmOWRkOQ.js>

**CVSS Score:** 9.1

**Technical Details:** Password found in JavaScript file.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Remove secrets from client-side JS. Use server-side environment variables.

---

## #14 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #15 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

---

## #16 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

---

## #17 [CRITICAL] SQLi — Data Extraction (Exploited)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** SQLi successfully exploited. Extracted: {'version': 'Holberton', 'user': 'Holberton', 'databases': 'Holberton', 'tables': 'Holberton', 'dump\_users': 'Holberton'}

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

IMMEDIATELY patch. Use parameterized queries.

---

## #18 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #19 [CRITICAL] CHAIN: SQLi → Credential Dump → Admin Takeover

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** SQL injection allows dumping the users/credentials table. Cracked or plaintext credentials can be used to log in as admin, achieving full application compromise.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use parameterized queries. Hash passwords with bcrypt/argon2. Enforce MFA on admin accounts.

---

## #20 [CRITICAL] CHAIN: LFI → Config Read → Credential Extraction

**Location:** <https://holbertonschool.az/api-docs/>

**CVSS Score:** 9.1

**Technical Details:** Local File Inclusion allows reading configuration files containing database credentials, API keys, and encryption secrets. These can be used to directly access the database or external services.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Move config files outside web root. Use secrets managers (Vault, AWS SSM). Restrict file path inputs — whitelist allowed files.

---

## #21 [CRITICAL] CHAIN: IDOR → PII Exfiltration → Mass Account Hijack

**Location:** <https://holbertonschool.az/admin/>

**CVSS Score:** 9.1

**Technical Details:** Insecure Direct Object References allow attackers to enumerate user IDs and access other users' data (emails, addresses, payment info). At scale, this enables mass PII exfiltration and account takeover.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement authorization checks on every resource access. Use UUID instead of sequential IDs. Log and alert on anomalous data access patterns.

---

## #22 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.8

**Technical Details:** JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. role:admin). This bypasses all role-based access controls.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

---

## #23 [CRITICAL] CHAIN: SQLi → Credential Dump → Admin Takeover

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** SQL injection allows dumping the users/credentials table. Cracked or plaintext credentials can be used to log in as admin, achieving full application compromise.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use parameterized queries. Hash passwords with bcrypt/argon2. Enforce MFA on admin accounts.

---

## #24 [CRITICAL] CHAIN: LFI → Config Read → Credential Extraction

**Location:** <https://holbertonschool.az/api-docs/>

**CVSS Score:** 9.1

**Technical Details:** Local File Inclusion allows reading configuration files containing database credentials, API keys, and encryption secrets. These can be used to directly access the database or external services.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Move config files outside web root. Use secrets managers (Vault, AWS SSM). Restrict file path inputs — whitelist allowed files.

---

## #25 [CRITICAL] CHAIN: IDOR → PII Exfiltration → Mass Account Hijack

**Location:** <https://holbertonschool.az/admin/>

**CVSS Score:** 9.1

**Technical Details:** Insecure Direct Object References allow attackers to enumerate user IDs and access other users' data (emails, addresses, payment info). At scale, this enables mass PII exfiltration and account takeover.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement authorization checks on every resource access. Use UUID instead of sequential IDs. Log and alert on anomalous data access patterns.

---

## #26 [CRITICAL] CHAIN: JWT None Algorithm → Admin Privilege Escalation

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.8

**Technical Details:** JWT with 'alg:none' or weak HS256 secret allows forging tokens with arbitrary claims (e.g. role:admin). This bypasses all role-based access controls.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Enforce RS256/ES256 algorithms. Reject 'none' algorithm. Validate all JWT claims server-side. Use short expiration times.

---



## #27 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #28 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

---

## #29 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

---

## #30 [CRITICAL] SQLi — Data Extraction (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** SQLi successfully exploited. Extracted: {'version': 'Holberton', 'user': 'Holberton', 'databases': 'Holberton', 'tables': 'Holberton', 'dump\_users': 'Holberton'}

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

[IMMEDIATELY patch. Use parameterized queries.](#)

---

## #31 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

[Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.](#)

---

## #32 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

[Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.](#)

---

## #33 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

[CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.](#)

---

## #34 [CRITICAL] RCE — Remote Code Execution (Exploited)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** Command 'whoami' executed. Output detected: 'administrator'

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

CRITICAL: Sanitize all shell inputs. Use subprocess with argument lists. Restrict OS command access from web layer.

---

## #35 [CRITICAL] SQLi — Data Extraction (Exploited)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** SQLi successfully exploited. Extracted: {'version': 'Holberton', 'user': 'Holberton', 'databases': 'Holberton', 'tables': 'Holberton', 'dump\_users': 'Holberton'}

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

IMMEDIATELY patch. Use parameterized queries.

---

## #36 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #37 [CRITICAL] SQLi — Data Extraction (Exploited)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 10.0

**Technical Details:** SQLi successfully exploited. Extracted: {'version': 'Holberton', 'user': 'Holberton', 'databases': 'Holberton', 'tables': 'Holberton', 'dump\_users': 'Holberton'}

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

IMMEDIATELY patch. Use parameterized queries.

---

## #38 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #39 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'theme'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #40 [CRITICAL] SQLi — Data Extraction (Exploited)

**Location:** https://holbertonschool.az

**CVSS Score:** 10.0

**Technical Details:** SQLi successfully exploited. Extracted: {'version': 'Holberton', 'user': 'Holberton', 'databases': 'Holberton', 'tables': 'Holberton', 'dump\_users': 'Holberton'}

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

IMMEDIATELY patch. Use parameterized queries.

---

## #41 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'q'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #42 [CRITICAL] XSS — Session Hijack Payload (Generated)

**Location:** https://holbertonschool.az

**CVSS Score:** 9.3

**Technical Details:** XSS confirmed in 'theme'. Cookie-stealing payload generated. Attacker can capture session tokens of authenticated users.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Implement strict CSP. Sanitize all output. Set HttpOnly + Secure flags on all session cookies.

---

## #43 [HIGH] Missing Header: Content-Security-Policy

**Location:** https://holbertonschool.az

**CVSS Score:** 7.5

**Technical Details:** CSP prevents XSS and data injection attacks by controlling allowed resource sources.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #44 [HIGH] Missing Header: Strict-Transport-Security

**Location:** <https://holbertonschool.az>

**CVSS Score:** 7.5

**Technical Details:** HSTS forces HTTPS connections and prevents SSL-stripping attacks.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #45 [HIGH] CVE: CVE-2017-16877

**Location:** <https://nvd.nist.gov/vuln/detail/CVE-2017-16877>

**CVSS Score:** 7.5 | **CVE:** CVE-2017-16877 (See NVD for details)

**Technical Details:** CVE-2017-16877 affects 'Next.js' — ZEIT Next.js before 2.4.1 has directory traversal under the /\_next and /static request namespace, allowing attackers to obtain sensitive information.

**[!] Attacker Impact / Scenario:**

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

**[+] Strategic Remediation:**

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

---

## #46 [HIGH] CVE: CVE-2018-6184

**Location:** <https://nvd.nist.gov/vuln/detail/CVE-2018-6184>

**CVSS Score:** 7.5 | **CVE:** CVE-2018-6184 (See NVD for details)

**Technical Details:** CVE-2018-6184 affects 'Next.js' — ZEIT Next.js 4 before 4.2.3 has Directory Traversal under the /\_next request namespace.

**[!] Attacker Impact / Scenario:**

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

**[+] Strategic Remediation:**

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

---

## #47 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 7.5

**Technical Details:** Tested 7 OTP codes with no lockout or 429 response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Enforce max 5 attempts. Add exponential backoff and account lockout.

---

**#48 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft**

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.8

**Technical Details:** Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Restrict CORS to trusted origins. Do not use wildcard (\*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

---

**#49 [HIGH] CHAIN: Open Redirect → Phishing → OAuth Token Steal**

**Location:** <https://holbertonschool.az/admin/>

**CVSS Score:** 7.4

**Technical Details:** An open redirect on the login page can be used to redirect OAuth authorization codes to an attacker-controlled server. The victim's session tokens are silently stolen.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Whitelist all redirect URLs. Never use user-supplied URLs in redirect\_uri without strict validation. Implement state parameter in OAuth flows.

---

**#50 [HIGH] Prototype Pollution — Server-Side (Query String)**

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[admin\]=true](https://holbertonschool.az?__proto__[admin]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[admin]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #51 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[role]=admin`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[role]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #52 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[isAdmin]=1`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[isAdmin]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #53 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[debug]=true`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[debug]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #54 [HIGH] Prototype Pollution — Server-Side (Query String)



**Location:** [https://holbertonschool.az?constructor\[prototype\]\[admin\]=true](https://holbertonschool.az?constructor[prototype][admin]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param 'constructor[prototype][admin]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #55 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?constructor\[prototype\]\[role\]=admin](https://holbertonschool.az?constructor[prototype][role]=admin)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param 'constructor[prototype][role]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #56 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_.admin=true](https://holbertonschool.az?__proto__.admin=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_.admin'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #57 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[privileged\]=true](https://holbertonschool.az?__proto__[privileged]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[privileged]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #58 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[isAuthenticated]=true`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[isAuthenticated]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #59 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[superuser]=1`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[superuser]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #60 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** `https://holbertonschool.az`

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #61 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #62 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #63 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #64 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #65 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #66 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #67 [HIGH] 2FA — No Rate Limiting on OTP (Brute-force Possible)

**Location:** https://holbertonschool.az/

**CVSS Score:** 7.5

**Technical Details:** Tested 7 OTP codes with no lockout or 429 response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Enforce max 5 attempts. Add exponential backoff and account lockout.

---

## #68 [HIGH] CHAIN: CORS Misconfiguration → XSS → Session Theft

**Location:** https://holbertonschool.az

**CVSS Score:** 8.8

**Technical Details:** Permissive CORS allows malicious origins to make authenticated API requests. Combined with XSS, attacker can send victim's session cookies to a controlled server via cross-origin fetch.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Restrict CORS to trusted origins. Do not use wildcard (\*) with credentials. Set HttpOnly + Secure + SameSite on cookies.

---

## #69 [HIGH] CHAIN: Open Redirect → Phishing → OAuth Token Steal

**Location:** <https://holbertonschool.az/admin/>

**CVSS Score:** 7.4

**Technical Details:** An open redirect on the login page can be used to redirect OAuth authorization codes to an attacker-controlled server. The victim's session tokens are silently stolen.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Whitelist all redirect URLs. Never use user-supplied URLs in redirect\_uri without strict validation. Implement state parameter in OAuth flows.

---

## #70 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[admin\]=true](https://holbertonschool.az?__proto__[admin]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[admin]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use Object.create(null) for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #71 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[role\]=admin](https://holbertonschool.az?__proto__[role]=admin)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[role]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #72 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[isAdmin]=1`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[isAdmin]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #73 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?__proto__[debug]=true`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`__proto__[debug]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #74 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** `https://holbertonschool.az?constructor[prototype][admin]=true`

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '`constructor[prototype][admin]`'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #75 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?constructor\[prototype\]\[role\]=admin](https://holbertonschool.az?constructor[prototype][role]=admin)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param 'constructor[prototype][role]'. Possible server-side JS pollution.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #76 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_.admin=true](https://holbertonschool.az?__proto__.admin=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_.admin'. Possible server-side JS pollution.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #77 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[privileged\]=true](https://holbertonschool.az?__proto__[privileged]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[privileged]'. Possible server-side JS pollution.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #78 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[isAuthenticated\]=true](https://holbertonschool.az?__proto__[isAuthenticated]=true)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[isAuthenticated]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #79 [HIGH] Prototype Pollution — Server-Side (Query String)

**Location:** [https://holbertonschool.az?\\_\\_proto\\_\\_\[superuser\]=1](https://holbertonschool.az?__proto__[superuser]=1)

**CVSS Score:** 8.1

**Technical Details:** Server returned prototype-related error for param '\_\_proto\_\_[superuser]'. Possible server-side JS pollution.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Use `Object.create(null)` for untrusted data. Freeze prototypes. Use schema validation (ajv).

---

## #80 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #81 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**



Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #82 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #83 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #84 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

### [!] Attacker Impact / Scenario:

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

### [+] Strategic Remediation:

Validate incoming JSON against strict schema. Strip \_\_proto\_\_ / constructor keys.

---

## #85 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** https://holbertonschool.az

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #86 [HIGH] Prototype Pollution — Server-Side (POST JSON)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 8.3

**Technical Details:** Server exposed prototype access error in JSON response.

**[!] Attacker Impact / Scenario:**

High risk of system compromise. Attackers could potentially gain unauthorized access, escalate privileges, or extract sensitive data.

**[+] Strategic Remediation:**

Validate incoming JSON against strict schema. Strip `__proto__` / constructor keys.

---

## #87 [MEDIUM] Exposed Path: `/api-docs/`

**Location:** <https://holbertonschool.az/api-docs/>

**CVSS Score:** 5.3

**Technical Details:** Path accessible with HTTP 200

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Review if this path should be publicly accessible. Add authentication if needed.

---

## #88 [MEDIUM] Exposed Path: `/admin/`

**Location:** <https://holbertonschool.az/admin/>

**CVSS Score:** 5.3

**Technical Details:** Path accessible with HTTP 200

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Review if this path should be publicly accessible. Add authentication if needed.

---

## #89 [MEDIUM] Missing Header: X-Frame-Options

**Location:** <https://holbertonschool.az>

**CVSS Score:** 6.1

**Technical Details:** Missing X-Frame-Options allows clickjacking attacks (embedding site in iframes).

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #90 [MEDIUM] CVE: CVE-2018-18282

**Location:** <https://nvd.nist.gov/vuln/detail/CVE-2018-18282>

**CVSS Score:** 6.1 | **CVE:** CVE-2018-18282 (See NVD for details)

**Technical Details:** CVE-2018-18282 affects 'Next.js' — Next.js 7.0.0 and 7.0.1 has XSS via the 404 or 500 /\_error page.

**[!] Attacker Impact / Scenario:**

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

**[+] Strategic Remediation:**

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

---

## #91 [MEDIUM] CVE: CVE-2020-5284

**Location:** <https://nvd.nist.gov/vuln/detail/CVE-2020-5284>

**CVSS Score:** 4.4 | **CVE:** CVE-2020-5284 (See NVD for details)

**Technical Details:** CVE-2020-5284 affects 'Next.js' — Next.js versions before 9.3.2 have a directory traversal vulnerability. Attackers could craft special requests to access files in the dist directory (.next). This does not affect files outside of the

**[!] Attacker Impact / Scenario:**

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

**[+] Strategic Remediation:**

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

---

## #92 [MEDIUM] CVE: CVE-2020-15242

**Location:** <https://nvd.nist.gov/vuln/detail/CVE-2020-15242>

**CVSS Score:** 4.7 | **CVE:** CVE-2020-15242 (See NVD for details)

**Technical Details:** CVE-2020-15242 affects 'Next.js' — Next.js versions  $\geq 9.5.0$  and  $< 9.5.4$  are vulnerable to an Open Redirect. Specially encoded paths could be used with the trailing slash redirect to allow an open redirect to occur to an external site. I

**[!] Attacker Impact / Scenario:**

Attackers can exploit this known vulnerability (CVE) to execute remote code, read sensitive server files, or hijack user sessions. This puts the entire infrastructure and customer data at critical risk.

**[+] Strategic Remediation:**

Immediately apply the official vendor patch for the identified technology. If patching is not immediately possible, apply WAF virtual patching and restrict access to the vulnerable component.

---

## #93 [MEDIUM] 2FA — Not Implemented

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.9

**Technical Details:** No 2FA/MFA endpoint detected.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

---

## #94 [MEDIUM] PostMessage — Page is Frameable (Clickjacking + postMessage Risk)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.4

**Technical Details:** No X-Frame-Options or CSP frame-ancestors header found. Attacker can embed this page in a frame and use postMessage to inject data into any vulnerable message listeners.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Add 'X-Frame-Options: DENY' or CSP 'frame-ancestors none'.

---

## #95 [MEDIUM] CSS Injection — Style Attribute Context

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.4

**Technical Details:** Parameter 'theme' is reflected inside a style attribute. Allows CSS property injection, background-image OOB data leak, and potential XSS via expression() in legacy browsers.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Validate CSS property values. Use allowlist for CSS values.

---

### #96 [MEDIUM] 2FA — Not Implemented

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.9

**Technical Details:** No 2FA/MFA endpoint detected.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Implement TOTP-based 2FA (FIDO2/WebAuthn/RFC 6238) for all accounts.

---

### #97 [MEDIUM] PostMessage — Page is Frameable (Clickjacking + postMessage Risk)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.4

**Technical Details:** No X-Frame-Options or CSP frame-ancestors header found. Attacker can embed this page in a frame and use postMessage to inject data into any vulnerable message listeners.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Add 'X-Frame-Options: DENY' or CSP 'frame-ancestors none'.

---

### #98 [MEDIUM] CSS Injection — Style Attribute Context

**Location:** <https://holbertonschool.az>

**CVSS Score:** 5.4

**Technical Details:** Parameter 'theme' is reflected inside a style attribute. Allows CSS property injection, background-image OOB data leak, and potential XSS via expression() in legacy browsers.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Validate CSS property values. Use allowlist for CSS values.

---

### #99 [LOW] Missing Header: X-Content-Type-Options

**Location:** <https://holbertonschool.az>

**CVSS Score:** 3.1

**Technical Details:** Missing header allows MIME-type sniffing, enabling content injection.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #100 [LOW] Missing Header: Referrer-Policy

**Location:** https://holbertonschool.az

**CVSS Score:** 3.1

**Technical Details:** Missing Referrer-Policy may leak sensitive URL information to third parties.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #101 [INFO] Subdomain Enum

**Location:** https://holbertonschool.az/

**CVSS Score:** N/A

**Technical Details:** Subdomain discovered: www.holbertonschool.az

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

---

## #102 [INFO] Port Scan

**Location:** holbertonschool.az:22

**CVSS Score:** N/A

**Technical Details:** Port 22 is open (SSH) — Banner: SSH-2.0-OpenSSH\_9.6p1 Ubuntu-3ubuntu13.16

**[!] Attacker Impact / Scenario:**

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

**[+] Strategic Remediation:**

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

---

## #103 [INFO] Port Scan

**Location:** holbertonschool.az:53

**CVSS Score:** N/A

**Technical Details:** Port 53 is open (DNS) — Banner:

### [!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

### [+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

---

## #104 [INFO] Port Scan

**Location:** holbertonschool.az:80

**CVSS Score:** N/A

**Technical Details:** Port 80 is open (HTTP) — Banner: HTTP/1.1 301 Moved Permanently

### [!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

### [+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

---

## #105 [INFO] Port Scan

**Location:** holbertonschool.az:443

**CVSS Score:** N/A

**Technical Details:** Port 443 is open (HTTPS) — Banner: HTTP/1.1 400 Bad Request

### [!] Attacker Impact / Scenario:

Exposed network services increase the attack surface. SSH, HTTP, and non-standard ports can be exploited for brute-force, service fingerprinting, and lateral movement.

### [+] Strategic Remediation:

Restrict port access via firewall rules. Only expose necessary services. Harden SSH with key-based auth and disable root login.

---

## #106 [INFO] Tech Detect

**Location:** https://holbertonschool.az/

**CVSS Score:** N/A

**Technical Details:** Technology detected: Nginx 1.24.0

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

---

## #107 [INFO] Web Crawler

**Location:** <https://holbertonschool.az/>

**CVSS Score:** N/A

**Technical Details:** -

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

---

## #108 [INFO] AWS S3

**Location:** <http://holbertonschool.s3.amazonaws.com>

**CVSS Score:** N/A

**Technical Details:** AWS S3 status: Exists (Access Denied) — <http://holbertonschool.s3.amazonaws.com>

**[!] Attacker Impact / Scenario:**

Publicly accessible cloud storage buckets (S3/GCP/Azure) can expose sensitive files, customer data, or application assets to unauthorized access or modification.

**[+] Strategic Remediation:**

Set bucket/blob ACL to private. Enable bucket versioning and logging. Use signed URLs for authorized access only.

---

## #109 [INFO] Infrastructure

**Location:** <https://holbertonschool.az/>

**CVSS Score:** N/A

**Technical Details:** Company: 15.236.0.0/15

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

---



## #110 [INFO] IP Prefixes

**Location:** <https://holbertonschool.az/>

**CVSS Score:** N/A

**Technical Details:** 2600:1f60:e080::/48, 99.86.9.0/24, 18.96.32.0/19, 2600:1fa0:80b0::/44, 65.9.60.0/24, 185.153.59.0/24, 2600:9000:2802::/48, 204.33.176.0/20, 52.84.216.0/24, 18.239.171.0/24...

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Follow security best practices and ensure all inputs are sanitized and dependencies updated.

---

## #111 [INFO] Exposed Path: /api-docs

**Location:** <https://holbertonschool.az/api-docs>

**CVSS Score:** 0.0

**Technical Details:** Path accessible with HTTP 301

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Review if this path should be publicly accessible. Add authentication if needed.

---

## #112 [INFO] Exposed Path: /admin

**Location:** <https://holbertonschool.az/admin>

**CVSS Score:** 0.0

**Technical Details:** Path accessible with HTTP 301

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Review if this path should be publicly accessible. Add authentication if needed.

---

## #113 [INFO] Exposed Path: /api

**Location:** <https://holbertonschool.az/api>

**CVSS Score:** 0.0

**Technical Details:** Path accessible with HTTP 301

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Review if this path should be publicly accessible. Add authentication if needed.

---

## #114 [INFO] Missing Header: Permissions-Policy

**Location:** <https://holbertonschool.az>

**CVSS Score:** 2.0

**Technical Details:** Missing Permissions-Policy allows access to powerful browser APIs (camera, mic, etc.).

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #115 [INFO] Missing Header: Cross-Origin-Opener-Policy

**Location:** <https://holbertonschool.az>

**CVSS Score:** 2.0

**Technical Details:** Missing COOP allows cross-origin pages to access window references.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #116 [INFO] Missing Header: Cross-Origin-Resource-Policy

**Location:** <https://holbertonschool.az>

**CVSS Score:** 2.0

**Technical Details:** Missing CORP allows cross-origin pages to load this site's resources.

**[!] Attacker Impact / Scenario:**

Missing security headers expose users to MIME-sniffing, Clickjacking, and Cross-Site Scripting. It weakens the client-side security posture significantly.

**[+] Strategic Remediation:**

Configure the web server to emit standard security headers: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options: nosniff, and Strict-Transport-Security (HSTS).

---

## #117 [INFO] Information Disclosure: X-Powered-By

**Location:** <https://holbertonschool.az>

**CVSS Score:** 2.0

**Technical Details:** Server technology disclosure may aid attacker fingerprinting.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Remove X-Powered-By header from all responses.

---

## #118 [INFO] Information Disclosure: Server

**Location:** https://holbertonschool.az

**CVSS Score:** 2.0

**Technical Details:** Server version disclosure may aid attacker fingerprinting.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Configure web server to omit or genericize the Server header.

---

## #119 [INFO] WAF Detected

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Web Application Firewall identified: Nginx (generic block). 0/8 attack payloads blocked.

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #120 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Encode payloads: URL / double-URL / HTML entity / Unicode

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #121 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Case variation: SeLeCt, UnIoN

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #122 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Comment insertion: UN/\*\*/ION SE/\*\*/LECT

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #123 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): HTTP Parameter Pollution

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #124 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Null byte injection: %00

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #125 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Content-Type switching: JSON/XML/multipart

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #126 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): Slow HTTP techniques

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #127 [INFO] WAF Bypass Technique — Nginx (generic block)

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Bypass technique for Nginx (generic block): IPv6 address in Host header

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #128 [INFO] WAF Bypass Payload — URL-encoded

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: %3Cscript%3Ealert%281%29%3C/script%3E

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #129 [INFO] WAF Bypass Payload — Double URL-encoded

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: %253Cscript%253Ealert%25281%2529%253C/script%253E

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #130 [INFO] WAF Bypass Payload — HTML-entity

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: <script>alert(1)</script>

### [!] Attacker Impact / Scenario:

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

### [+] Strategic Remediation:

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #131 [INFO] WAF Bypass Payload — Unicode escape

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: <script>alert(1)</script>

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #132 [INFO] WAF Bypass Payload — Hex (JS)

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Encoded variant:

\x3c\x73\x63\x72\x69\x70\x74\x3e\x61\x6c\x65\x72\x74\x28\x31\x29\x3c\x2f\x73\x63\x72\x69\x70\x74\x3e

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #133 [INFO] WAF Bypass Payload — Base64

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: PHNjcmlwdD5hbGVydCgxKTWvc2NyaXB0Pg==

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #134 [INFO] WAF Bypass Payload — Null-byte

**Location:** https://holbertonschool.az/

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: ■<script>alert(1)■</script>

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #135 [INFO] WAF Bypass Payload — Tab-obfuscated

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: `<scr ipt>alert(1)</scr ipt>`

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #136 [INFO] WAF Bypass Payload — Case-mixed

**Location:** <https://holbertonschool.az/>

**CVSS Score:** 0.0

**Technical Details:** Encoded variant: `<sCrIpT>AlErT(1)</ScRiPt>`

**[!] Attacker Impact / Scenario:**

Attackers can bypass the Web Application Firewall using encoded payloads (Hex, Base64, Unicode). This renders the WAF ineffective and exposes the backend to direct injection attacks.

**[+] Strategic Remediation:**

Update WAF rulesets to decode and normalize all incoming traffic before signature analysis. Ensure strict input validation on the backend regardless of WAF presence.

---

## #137 [INFO] Recon — Discovered API Endpoints in JS

**Location:** [https://holbertonschool.az](https://holbertonschool.az/)

**CVSS Score:** 0.0

**Technical Details:** Found 1 API endpoints via JS analysis.

**[!] Attacker Impact / Scenario:**

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

**[+] Strategic Remediation:**

Ensure all discovered endpoints require authentication.

---



## #138 [INFO] Recon — Observed API Calls (XHR/fetch)

**Location:** <https://holbertonschool.az>

**CVSS Score:** 0.0

**Technical Details:** Observed 25 XHR/fetch calls during crawl.

### [!] Attacker Impact / Scenario:

Could aid attackers in reconnaissance or be chained with other vulnerabilities to compromise the application.

### [+] Strategic Remediation:

[Review all API calls for missing authentication.](#)

---